

30.6, 2025

Basant Sir

CSE-429
(Security)

Books :

1. Cryptography & Network Security → William Stallings.
2. Cyber Security → Nina Godbole, Sunit Belapore.
3. Cyber Security for Beginners → Raef Meeuwisse

Syllabus :

1. Fundamentals / Basics
2. Threats / Attacks / Vulnerabilities.
3. Mitigation / way out
4. Advanced features, architectures, Models.

cyber → domain → data, network → security

cybersecurity → network & security ensure that

→ is a process to protect, net, computer, data, s/w systems

CIA → Confidentiality : secured data while transmission,
Triad access to limited/authenticated person
Integrity : no alteration/modification while transmission

Availability : 24/7 available ← system/service

Malware → Malicious Software

↳ affects the computer system

- Virus, worm, trojan horse

- * Info bak
- * take control/ownership

• Virus → Vital Info Resources under Siege

↳ self replicate, needs a host program

• Worm → computer system এ ছড়ায়

↳ does not need a host program to spread

• Trojan Horse → acts like a legitimate S/W

↳ disguised malicious S/W, does not self replicate

(Trojan horse)

• Rootkit

↳ goes to the admin level of computer

→ administrator level এ conceal করে রাখে

• Spyware → one type of malware who collects

'need to know' info.

• ransomware

↳ system hijack/control নিজেই করে নেয়

কিন্তু ফিফিফিফি refraction

• adware → not that much harmful

↳ ads on a media

ATG
bait

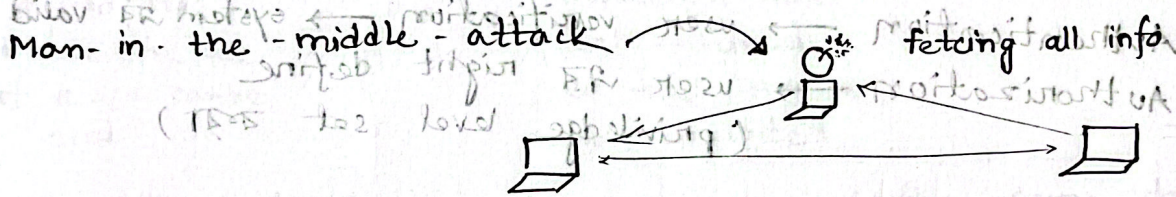
Types of Attack :

DoS → Denial of Service → single intruder.
(unauthorized user system access)

DDoS → Distributed DoS
1000s/100s of bots / more intruders.

Salami attack → .50 → 1
additional amount

don't give that much attention to this type of attack though it occurs openly.



Bangladesh Bank → Phishing
(sent cv links to some high officials)

(social engineering → observes the user's interest first. Then send that type of email/links/sms. to the user)

Sniffing → (password sniffing/cracking)

60% p/w cracked → by pattern matching.

→ brute force attack → tests of all possible combination of passwords.

eavesdropping → intruder keeps observing the whole situation

Email spoofing → sender identity use attacker's mail send receiver.

attacker → user header of CEO → receiver
(act like CEO's mail)

Email Bombing → lots of emails are sent
(somewhat like DoS)

• DNS — Domain name system
(mapping of website name & IP address)

• CIA
├── Availability
├── Integrity
└── Confidentiality

• Authentication → user verification → system is valid user is
Authorization → user is right define
(privilege level set etc)

• MFA — multi factor authentication

(1) OTP send via msg / email

(2) Biometric

(3) password

Authentication → knowledge based authentication
(something you know)

Ex: ID, password

Position based authentication
(something you have)

Ex: RF ID, OTP

Inheritance based

Ex: Biometric

(voice recog, face recog,

Fingerprint)

→ Adaptive authentication

(multiple login / location change etc,
mail send)

FA doesn't
belong to this
classification

* Internet time theft.

- ~~data~~ data/wifi use

• Data Diddling → data alteration on input

Webgoat



Website → vulnerabilities → identify

(App platform where live use of a s/w can be done.

Protection must be ensured so that they are not exploited.

new feature add
new version launch

• 0-day attack → s/w launching / after some days / years, attack → s/w vulnerabilities attack.

→ fatal-day attack
attack is difficult, but manipulation is easy.

• Rainbow attack

hash algo → word ⇒ hash value generate

↓
As a table → rainbow table
(where hash values are stored).

interversible → Fahim → 87

←
cannot know what's the word from the hash value

Attack on the hash values → rainbow attack

add salt ← to avoid this
(add some random numbers)
generated by system.

* cryptography $\rightarrow$ $\begin{matrix} \text{encrypt} \\ S \xrightarrow{(key)} R \\ \text{(key)} \end{matrix}$

steganography $\rightarrow$ image $\rightarrow$ text/info hide

session hijacking $\rightarrow$ session बनाये रखें, निले

$\rightarrow$ (website रहने $\rightarrow$ webjacking)

Bug $\rightarrow$ code में error

Flaw $\rightarrow$ s/w design में fault/defect $\rightarrow$ architectural error

easier to fix

rainbow attack

rainbow table $\rightarrow$ password $\rightarrow$ hash value

rainbow table $\rightarrow$ password $\rightarrow$ hash value

rainbow table $\rightarrow$ password $\rightarrow$ hash value

rainbow table $\rightarrow$ password $\rightarrow$ hash value

rainbow table $\rightarrow$ password $\rightarrow$ hash value

rainbow table $\rightarrow$ password $\rightarrow$ hash value

rainbow table $\rightarrow$ password $\rightarrow$ hash value

- Fail open

પ્રભવન જરૂરી security measure/state,
 યદિ જાણના system vulnerable રહ્યું,
 attacker attack યાત્રે ના યજ્ઞરત જાત્રે

fail of market system $\rightarrow$ fail रहल $\rightarrow$ secure.

opened (Vif → this algo works)
(cyber security ~~to~~ → attackers can attack)
at this state

- legitimate user.

- एतत्तु -

→ backdoor open $\rightarrow$ 200 - day attack

(vulnerability) का माह

com. thrombocytes barbiv ← : protein 5/w owner / develop ज्ञान

exploit vulnerability $\leftarrow 1$
after S/W launch.

after S/W launch.

100 windows hardening → security policy → customize

• login spoofing → After sending phishing link

software engi → 24 hrs 7 days
আপনার কাছে
link মাঠে
attacker sent mail (malicious)
Taken to a false website just
like bank's website
give credentials.

• App locker → a policy → allow apps
white listing : websites that are allowed in the system
Black : system is restricted.

App locker → amount বস → তার list create
App locker → microsoft windows এর feature is
listing

• Sandboxing / Jailing : → virtual compartment create.

malicious app → system → secure mode এ চলে (quarantine)

• Patch management :

- update ← নতুন feature / vulnerability fix
→ patch → security mechanism add করে ,
- releasing the updates .

21. 7. 2025

182 - 10th April

char (10) (22x) printf site 2000
(input) (100) ← site 2000
gets (input) ← site 2000
overflow

c ✓

python, c-sharp $\xrightarrow{\text{motivation}}$ safer

Integer overflow attack

int $\rightarrow$ o/p allocated memory भिन्न रत्न

wabbot?

1. SQL Injection
2. Cross Site Scripting (XSS)
3. Cross Site Request Forgery (CSRF)
4. Wi-Fi Eavesdropping
5. Brute Force Attack

③ SQL Injection → database system
malicious SQL code → info retract/delete
~ authentication bypass
~ deleting/altering/stealing/retrieving data.

Ex: -select * FROM users

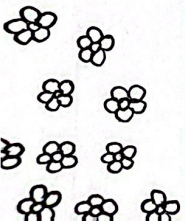
where userid = 'OR '1'='1' & password = 'passw
all user id access 24x7

XSS → cookies and credentials stolen (data steal)

CSRF → forces/manipulates user to fall into trap.
(needs social engineering).
(user falls into trap ← request wise)

✓ XSS
✓ SQL
✓ websites are accessed

request state change
(code and data)



interception

④ wifi eavesdropping

how mobile & internet connects?
" " " mobile "

~ use wireshark

password sniffing

⑤ BFA — manually / SW based.

all combo. of password → try.

↓
to prevent → restrict

with
attempt
count

3-বারের বেশি
wrong হলে
restrict access